

[INC-20260911-042] Suspicious Network Traffic - Lumma Stealer (LUMMAC.V2) Activity

Executive Summary (Incident Write-up):

During our triage, we detected anomalous outbound HTTP and DNS activity originating from an internal workstation within the corporate network. Packet inspection revealed that the host made recurring requests to newly observed external domains, beginning with an initial beaconing request to know.mom-nower.com that returned an HTTP 204 No Content response to confirm connectivity. Following this handshake, the client downloaded encrypted 91-byte configuration tasking via HTTP 200 OK responses and subsequently initiated multiple outbound HTTP POST requests carrying application/octet-stream payloads to secondary infrastructure (stream.fif-lost.com, gets.bert-hits.com, and firt.comonto-rsr.com). All suspicious requests embedded a static 64-character session hash and simulated legitimate CSRF tokens to blend into normal web browsing.

Artifacts:

- Host Name: DESKTOP-6T17ZFM
- IP Address: 10.9.11.135
- MAC Address: 08:d4:0c:7a:29:1e
- User/S: gmcldowell (Gabriel McDowell)
- OS Type: WINDOWS 10
- Date/Time that the event was noticed: 09/11/2026 20:06 UTC
- Alert time stamp: 09/11/2026 20:06 UTC
- Number of systems identified: 1 Endpoint (Workstation) / 1 Domain Controller (10.9.11.2 - WIN-GTWXC9UYSE4)

Text explaining why below data is important to IOCs:

The network forensics indicate active infection by the information-stealing Trojan known as Lumma Stealer (cataloged under the alias LUMMAC.V2 in threat repositories). This malware family focuses on stealing browser credentials, autofill profiles, credit cards, cryptocurrency wallet extensions, and system hardware telemetry. The observed HTTP POST transactions with binary payloads confirm successful host profiling and active staging for exfiltration, while the redundant domain requests demonstrate an active multi-node C2 fallback infrastructure.

Declaration:

True Pos. - Issue, because of that was a dynamic incident.

Recommendations:

- Isolation of the infected system: Immediately isolate workstation DESKTOP-6T17ZFM (10.9.11.135) from the network via EDR to prevent lateral movement and further exfiltration.
- Blocking malicious URLs and IP addresses: Enforce perimeter firewall, proxy, and DNS sinkhole rules for the resolved C2 IP addresses (86.106.87.134, 62.3.53.87, 104.21.80.122, 172.67.220.220) and associated domains.

- Credential Revocation & Identity Reset: Invalidate all active Kerberos ticket-granting tickets (TGT), reset domain credentials for Gabriel McDowell (gmcdowell), and revoke all corporate browser session cookies.
- Purge and Revoke Stored Secrets: Advise the user to reset any personal or corporate accounts accessed from this endpoint, particularly password managers and cryptocurrency wallets.
- Endpoint Remediation: Perform forensic triage on the host drive to identify the initial dropper path, terminate persistence mechanisms, and re-image the workstation prior to production redeployment.

References:

- <https://www.virustotal.com/>
- <https://malpedia.caad.fkie.fraunhofer.de/>
- <https://bazaar.abuse.ch/>
- <https://www.malware-traffic-analysis.net/2026/09/11/index.html>

OSINT Links:

- VirusTotal Classification: Associated C2 IP infrastructure and domain analysis (Categorized as Lumma Stealer C2 nodes):
<https://www.virustotal.com/gui/ip-address/86.106.87.134>
<https://www.virustotal.com/gui/domain/now.comonto-rsr.com>
- Malpedia Threat Alias: Confirmed as Lumma Stealer (LUMMAC.V2):
<https://malpedia.caad.fkie.fraunhofer.de/details/win.lumma>
- Abuse.ch URLhaus / Threat Fox: Tracked Lumma Stealer active campaign endpoints and exfiltration gate indicators:
<https://threatfox.abuse.ch/ThreatFox | LummaStealerh/browse/tag/LummaStealer/>